

ESERCIZIO Prompt per ChatGPT

Ho chiesto a chatGPT di illustrarmi le tecniche di social engineering come se fossi uno sconosciuto alla prime armi in modo da ricevere una risposta più completa e dettagliata e alla stesso tempo chiara.

Questa la domanda effettuata: ciao, sono novello in materia cyber sicurezza, potresti spiegarmi in modo dettagliato e semplice cos'è il social engineering e descrivere le tecniche più comuni utilizzate dagli attaccanti?

Questa è stata la risposta fornita dall'IA

.Ciao! ☺

Certo, ti spiego il **social engineering** in modo **semplice ma completo**, partendo dalle basi e poi vedendo le tecniche più usate.

Cos'è il Social Engineering

Il **social engineering** (ingegneria sociale) è un insieme di tecniche usate dai criminali informatici per **manipolare le persone** e spingerle a fare qualcosa che **non farebbero normalmente**, come:

- rivelare password o codici
- cliccare su link malevoli
- scaricare file infetti
- concedere accessi a sistemi o informazioni riservate

☐ Punto chiave:

non si attaccano i computer, **si attaccano le persone**.

Gli esseri umani sono spesso l'anello più debole della sicurezza, perché:

- si fidano
- hanno fretta
- provano paura o curiosità
- vogliono aiutare

Gli attaccanti sfruttano proprio queste emozioni.

Come funziona un attacco di Social Engineering

Di solito segue questi passi:

1. **Raccolta informazioni**

L'attaccante cerca dati sulla vittima (social network, sito aziendale, email pubbliche).

2. **Creazione di una storia credibile**

Si finge qualcuno di affidabile (banca, collega, tecnico IT, corriere).

3. **Manipolazione psicologica**

Usa urgenza, paura, autorità o curiosità.

4. **Azione della vittima**

La vittima clicca, risponde, fornisce dati o installa qualcosa.

Tecniche più comuni di Social Engineering

1. Phishing ☐ (la più diffusa)

Invio di **email, SMS o messaggi** che sembrano provenire da fonti legittime.

Esempio:

“Il tuo conto è stato bloccato. Clicca qui per verificare.”

Obiettivo:

- rubare credenziali
- installare malware

Varianti:

- **Spear phishing:** mirato a una persona specifica
 - **Whaling:** mirato a dirigenti o CEO
-

2. Vishing ☐ (Voice Phishing)

Attacco tramite **telefonata**.

Esempio:

“Sono dell'assistenza tecnica, abbiamo rilevato un problema sul tuo account.”

Spesso l'attaccante:

- parla in modo sicuro
 - usa termini tecnici
 - crea urgenza
-

3. Smishing ☐ (SMS Phishing)

Phishing tramite **SMS o WhatsApp**.

Esempio:

“Pacco in consegna. Conferma i dati qui.”

Molto efficace perché:

- i messaggi sembrano brevi e urgenti
 - si tende a fidarsi di più del telefono
-

4. Pretexting ☐

L'attaccante crea un **pretesto**, una storia dettagliata.

Esempio:

“Sono un nuovo collega del reparto IT, devo verificare il tuo accesso.”

Qui la forza è la **credibilità della storia**.

5. Baiting ☐

Si offre qualcosa di allettante per attirare la vittima.

Esempi:

- chiavetta USB trovata “per caso”
- download gratuito di software pirata
- “contenuti esclusivi”

➡ ☐ Una volta usati, possono installare malware.

6. Quid Pro Quo ☐

“Qualcosa in cambio di qualcos'altro”.

Esempio:

“Ti aiuto a risolvere un problema tecnico se mi dai le credenziali.”

Spesso usato fingendosi supporto IT.

7. Tailgating / Piggybacking ☐

Attacco **fisico**.

Esempio:

Una persona entra in un edificio protetto seguendo qualcuno che apre la porta:

“Ho dimenticato il badge, puoi farmi entrare?”

Sfrutta la **cortesia**.

Le leve psicologiche più usate

Gli attaccanti fanno leva su:

- **Urgenza** → “Agisci subito!”
 - **Paura** → “Il tuo account è compromesso”
 - **Autorità** → “Lo dice il tuo capo”
 - **Curiosità** → “Guarda questo file”
 - **Empatia** → “Ho bisogno di aiuto”
-

Come difendersi (in breve)

Anche se sei novello, ricordati queste regole base:

- Diffida di messaggi **urgenti**
 - Non cliccare link sospetti
 - Verifica sempre l’identità del mittente
 - Non condividere mai password
 - Se qualcosa “ti mette fretta”, fermati
-

Se vuoi, nel prossimo messaggio posso:

- mostrarti **esempi reali di email di phishing**
- spiegarti **come riconoscerle passo per passo**
- simulare un **attacco e analizzarlo insieme**

Dimmi tu ☐

Come seconda domanda per ricevere dei suggerimenti di difesa ho chiesto all'IA: adesso nel dettaglio protesti elencarmi e spiegarmi le strategie più efficaci per difendersi dagli attacchi?

Così ha fornito risposta l'IA

Certo! 📄

Ti propongo una spiegazione **dettagliata ma chiara**, pensata proprio per chi è all'inizio. Dividerò le **strategie di difesa** in aree, così è più facile capirle e ricordarle.

Strategie efficaci per difendersi dal Social Engineering

1. Consapevolezza e formazione (la difesa più importante)

☐ La miglior difesa è la conoscenza

Il social engineering funziona perché:

- non lo si conosce
- si reagisce d'istinto

Cosa fare:

- conoscere le tecniche più comuni (phishing, vishing, smishing)
- sapere che **nessuna azienda seria chiede password via email o telefono**
- allenarsi a riconoscere segnali sospetti

☐ Più sei consapevole, meno sei manipolabile.

2. Gestione delle email e dei messaggi

Controllare sempre:

- **mittente reale** (non solo il nome)
- errori grammaticali o traduzioni strane
- link accorciati o sospetti
- allegati inattesi

Buone pratiche:

- passa il mouse sopra i link prima di cliccare
- non aprire allegati non richiesti
- elimina email “troppo belle per essere vere”

☐ Regola d'oro: *se non te lo aspettavi, diffida.*

3. Verifica dell'identità (mai fidarsi al 100%)

Se qualcuno ti contatta e chiede informazioni:

Fermati e verifica:

- richiama tu usando un numero ufficiale
- contatta direttamente l'azienda o il collega
- usa un altro canale (es. telefono invece di email)

☐ Non usare mai i contatti forniti nel messaggio sospetto.

4. Gestione sicura delle password

Strategie fondamentali:

- password **lunghe e uniche**
- una password diversa per ogni servizio
- usare un **password manager**

Mai fare:

- riutilizzare la stessa password
- inviare password via email o chat
- salvarle in chiaro

☐ Se una password viene rubata, le altre restano al sicuro.

5. Autenticazione a due fattori (2FA / MFA)

☐ Aggiunge un secondo livello di sicurezza:

- codice temporaneo
- app di autenticazione
- chiave fisica

Anche se un attaccante ruba la password, **non può entrare.**

☐ Attivala ovunque sia possibile.

6. Gestione dei social network

Gli attaccanti usano i social per raccogliere informazioni.

Limita:

- dati personali pubblici
- dettagli su lavoro, ferie, ruoli aziendali
- foto di badge, scrivanie, documenti

☐ Meno informazioni = attacco più difficile.

7. Sicurezza del dispositivo

Buone pratiche:

- sistema operativo aggiornato
- antivirus/antimalware attivo
- firewall abilitato
- blocco schermo automatico

Un dispositivo sicuro **riduce i danni** anche se sbagli.

8. Diffidare dell'urgenza e delle emozioni

☐ L'urgenza è il segnale più forte di un attacco.

Se un messaggio:

- ti mette fretta
- ti spaventa
- ti promette un premio

➡ ☐ **Fermati e rifletti.**

Chiediti:

“Agirei così se avessi più tempo?”

9. Politiche e procedure (soprattutto in azienda)

Le aziende dovrebbero avere:

- procedure chiare per richieste di dati
- regole su chi può chiedere cosa
- canali ufficiali di comunicazione

☐ Se una richiesta **non segue la procedura**, è sospetta.

10. Non avere paura di dire “NO”

Molti attacchi riescono perché:

- non si vuole sembrare scortesi
- si vuole aiutare

☐ È sempre meglio sembrare scortesi che essere violati.

11. Cosa fare se sospetti un attacco

1. Non cliccare, non rispondere
2. Non fornire informazioni
3. Segnala il messaggio
4. Cambia le password se hai dubbi
5. Avvisa IT o supporto

Agire velocemente **limita i danni**.

Riassunto rapido (da ricordare)

- ✓ Diffida dell'urgenza
 - ✓ Verifica sempre l'identità
 - ✓ Password uniche + 2FA
 - ✓ Meno info online
 - ✓ Aggiorna i dispositivi
 - ✓ Fermati prima di agire
-

Se vuoi, nel prossimo passo posso:

- creare una **checklist pratica anti-phishing**
- analizzare **un caso reale di attacco**
- spiegarti **come si difendono le aziende**
- farti un **mini test** per allenarti a riconoscerli

Questo esercizio mette in evidenza che il social engineering sfrutta principalmente il **fattore umano**, più che le debolezze tecniche. La difesa più efficace è quindi la **consapevolezza**, unita a buone pratiche come la verifica delle richieste, la gestione sicura delle password e la capacità di fermarsi davanti a messaggi urgenti o sospetti. In **conclusione**, anche poche regole applicate con attenzione possono ridurre in modo significativo il rischio di attacco.

Mentre per quanto riguarda l'utilizzo dell'IA con prompt specifici, ho ricevuto risposte dettagliate e corrette in un tempo molto breve a conferma che in molti casi può fornire assistenza, semplificare e diminuire i tempi di lavorazione.